

Technology Cloud Compromise
Tabletop Exercise

Nimbus SaaS Platform | Technology Sector | Cloud Administrator Account Compromise

Generated from STIX 2.1 scenario bundle dated 22 June 2026. This exercise simulates unauthorized administrator access, IAM manipulation, and access to customer data within the Cloud Management Environment.

Exercise duration	Audience	Primary focus
90 minutes	Executive crisis cell, SOC/IR, Cloud/IAM, Legal, Privacy, Communications, Customer Success	Cloud identity compromise, data exposure assessment, customer/regulatory decision-making

1. Introduction

This tabletop exercise is designed to help Nimbus SaaS Platform rehearse response to a realistic cloud administrator account compromise. The scenario is fictional but grounded in the provided STIX elements: a crime-syndicate style actor named Cloud Access Broker; attack patterns involving Valid Accounts, Account Manipulation, and Data from Cloud Storage; and injects covering suspicious cloud activity, IAM changes, customer data access, and notification decisions.

The exercise emphasizes decision quality, escalation clarity, evidence preservation, safe containment, cloud service provider coordination, customer impact assessment, and governance alignment between technical responders and executive leadership.

2. Exercise Scope and Assumptions

- In scope: Cloud Management Environment, cloud IAM, cloud storage, administrator accounts, audit logging, customer information, SaaS application configuration data, incident response governance, customer/regulatory communications.
- Out of scope: live technical testing, production changes, attribution beyond the fictional actor, and assessment of any named real cloud provider.
- Assumption: suspicious administrator activity begins before normal business hours and is initially detected by cloud monitoring rather than by a customer complaint.
- Assumption: no destructive malware is observed; the priority is containment, privilege integrity, evidence preservation, and data exposure determination.
- Assumption: legal and privacy teams determine notification obligations based on actual jurisdictional exposure, contractual obligations, and evidence of access or exfiltration.

3. Exercise Objectives

Objective	What good looks like
Validate cloud incident escalation	SOC, cloud platform owners, crisis leadership, legal/privacy, and communications know when and how to engage.
Test identity containment decisions	Teams can disable compromised accounts, revoke sessions, rotate secrets, preserve evidence, and avoid disrupting business-critical SaaS operations unnecessarily.
Assess IAM recovery and assurance	Unauthorized roles, keys, policies, service principals, tokens, and access paths are identified, removed, and independently validated.
Practice data exposure governance	Teams distinguish unauthorized access, confirmed exfiltration, customer impact, notification thresholds, and contractual reporting requirements.
Improve executive decision-making	Leadership receives timely facts, clear uncertainty statements, options, risk tradeoffs, and communication recommendations.

4. Rules of Engagement

- Real incidents take priority. Participants may step out if required, but should notify the facilitator.
- There are no right or wrong answers. The exercise is a safe environment to identify gaps and improve response practices.
- Suspend disbelief. Treat the scenario as real and respond according to actual roles, authorities, and processes.
- Do not fight the scenario. Ask clarifying questions, but work with the injects as provided.
- Decisions should identify owner, rationale, timing, dependencies, and communications impact.

5. Participant Roles

Role / Function	Primary responsibilities during exercise
Executive / Crisis Lead	Set priorities, approve major communications, decide crisis posture, ensure business and customer impacts are managed.
SOC / Incident Response	Triage alerts, preserve logs, scope activity, recommend containment, coordinate forensic investigation.
Cloud Platform / IAM	Validate identities, revoke access, review policies, restore known-good permissions, verify logging and storage exposure.
Legal / Privacy	Assess notification obligations, privilege, evidence handling, customer data exposure, regulator engagement.
Communications / Customer Success	Prepare internal, customer, and partner messaging; align timing and content with facts and legal guidance.
Business / Product Owners	Assess operational impact, customer commitments, service continuity, and product/platform dependencies.

6. Scenario Narrative

Nimbus SaaS Platform operates a SaaS platform supported by a centralized Cloud Management Environment. The environment includes cloud IAM, storage, administrative management services, audit logging, secrets, and application configuration repositories. A financially motivated access broker has obtained or purchased working administrator credentials and is using them to blend into legitimate cloud operations.

The attacker first uses a valid administrator account from an unusual geographic region. After establishing access, they create new privileged roles and modify existing administrator permissions to preserve access. Audit logs then show access to storage locations containing customer information and application configuration data. Leadership must decide how to contain the event, assure the integrity of cloud IAM, assess exposure, and communicate with customers, regulators, and the cloud service provider.

7. Master Timeline

Exercise time	Inject	Event summary	Primary decision focus
Day 1 - 08:45	1 - Suspicious Cloud Activity	Cloud monitoring detects administrator API calls from a region not previously associated with the organization.	Triage, escalation, evidence preservation, account risk.
Day 1 - 10:15	2 - IAM Modification	Unauthorized privileged roles and administrator permission changes are identified.	Containment, privilege review, business continuity.
Day 1 - 13:30	3 - Customer Data Access	Audit logs show unauthorized access to cloud storage containing customer information and application configuration data.	Exposure assessment, forensic scope, customer risk.
Day 2 - 09:00	4 - Customer and Regulatory Notification	Executive leadership must determine notification requirements and external engagement.	Governance, notification, regulator/customer communications.

8. Inject Detail and Facilitator Guide

Inject 1 - Suspicious Cloud Activity

Time	Inject message to participants
Day 1 - 08:45	Cloud monitoring detects administrator API calls originating from a geographic region not previously associated with Nimbus SaaS Platform.

What participants know at this stage

- Determine whether the activity is benign administrator travel, VPN/proxy use, compromised credentials, or an automation misconfiguration.
- Confirm whether the administrator account is interactive, service-linked, or break-glass.
- Preserve relevant cloud audit logs, identity provider logs, conditional access decisions, session data, and source IP evidence.
- Define initial severity and escalation path.

Discussion questions

- Has the SOC opened an incident and notified the cloud platform owner?
- Should the affected administrator session be terminated immediately, monitored briefly for scoping, or disabled pending validation?
- Who can approve emergency controls such as temporary admin restrictions or conditional access changes?
- What evidence must be preserved before containment actions alter logs or sessions?

Facilitator notes / expected actions

- Record time of detection and first response actions.
- Avoid assuming false positive solely because valid credentials were used.
- Encourage participants to state uncertainty and identify minimum facts needed for escalation.
- Expected actions: open incident, preserve logs, contact account owner out-of-band, review recent admin actions, restrict risky session, check MFA/IdP events, and notify incident leadership if privileged access is suspected.

Inject 2 - IAM Modification

Time	Inject message to participants
Day 1 - 10:15	Investigation reveals creation of new privileged roles and modification of existing administrator permissions without authorization.

What participants know at this stage

- Identify all new or modified IAM principals, roles, policies, access keys, service accounts, OAuth grants, and privilege assignments.
- Contain unauthorized access while maintaining safe operation of the SaaS platform.
- Assess whether identity changes created persistence or backdoor access paths.
- Align SOC, IAM, cloud engineering, and crisis leadership decisions.

Discussion questions

- Who owns the decision to revoke roles and rotate secrets?
- Can the team restore IAM from known-good configuration or infrastructure-as-code baselines?

- What business services may be disrupted by broad credential revocation?
- What is the threshold for activating the corporate crisis cell or executive incident team?

Facilitator notes / expected actions

- Look for clear separation of duties: SOC recommends containment; IAM/cloud teams execute validated changes; crisis leadership manages business risk.
- Expected actions: disable compromised admin, revoke active sessions, rotate secrets, suspend unauthorized roles, compare IAM to baseline, preserve evidence, increase cloud logging, check for created access keys and service principals, and update severity if persistence is confirmed.

Inject 3 - Customer Data Access

Time	Inject message to participants
Day 1 - 13:30	Audit logs indicate unauthorized access to cloud storage containing customer information and application configuration data.

What participants know at this stage

- Determine what data was accessed, whether data was viewed, listed, downloaded, copied, or exfiltrated, and which customers may be affected.
- Assess sensitivity of application configuration data, including secrets, environment variables, encryption keys, and tenant configuration.
- Engage legal, privacy, customer success, and communications teams with a fact-based situation report.
- Decide whether to take additional containment steps such as storage access freezes, key rotation, or temporary customer-facing mitigations.

Discussion questions

- What evidence distinguishes access from exfiltration?
- What customer segments, jurisdictions, contracts, and regulatory obligations are implicated?
- Should customer support receive holding statements now, before notification decisions are finalized?
- Do application configuration exposures create follow-on risk to production systems or customers?

Facilitator notes / expected actions

- Push participants to define an exposure assessment process rather than jumping to notification conclusions.
- Expected actions: export and protect audit logs, inventory accessed buckets/objects, identify customers and data fields, review egress logs, rotate exposed secrets/keys, check for unusual downloads, prepare legal-preserved timeline, and brief executives with confirmed facts and unknowns.

Inject 4 - Customer and Regulatory Notification

Time	Inject message to participants
Day 2 - 09:00	Executive leadership must determine breach notification requirements, customer communications, and engagement with regulators and cloud service providers.

What participants know at this stage

- Make notification decisions using evidence, legal thresholds, contractual commitments, customer impact, and reputational risk.
- Coordinate consistent messaging across customers, regulators, cloud provider, employees, board, and support channels.

- Define recovery assurance criteria before declaring the incident contained.
- Capture lessons learned and assign remediation owners.

Discussion questions

- What exactly can be said externally without overstating or understating the facts?
- Who approves regulator and customer communications?
- What commitments can Nimbus make regarding remediation, monitoring, and customer support?
- What evidence is required before closing the incident or downgrading severity?

Facilitator notes / expected actions

- Expected actions: legal/privacy notification assessment, executive approval, customer segmentation, regulator engagement plan, cloud provider support request, board briefing, final containment validation, post-incident report, control improvement backlog, and after-action review.
- Encourage discussion of communications timing, transparency, privilege, and consistency.

9. Decision Points

Decision point	Trigger	Decision owner	Expected decision criteria
Disable compromised account	Unusual admin session and unauthorized activity	SOC with IAM execution	Privilege level, active session risk, evidence preservation, business dependency.
Emergency IAM lockdown	Unauthorized roles or policies found	Cloud/IAM lead with crisis approval if service impact expected	Scope of persistence, availability impact, ability to restore from baseline.
Escalate to executive crisis management	Potential customer data exposure or material service/customer impact	Incident commander / CISO	Severity, customer impact, regulatory risk, reputational exposure.
Notify customers/regulators	Evidence of customer data access or exfiltration threshold met	Executive leadership with Legal/Privacy	Jurisdiction, contract, sensitivity, confirmation level, timeline requirements.

10. Technical and Business Impacts

Impact area	Potential consequences	Mitigation focus
Cloud IAM integrity	Unauthorized privilege escalation, persistence, hidden roles, policy drift.	Baseline comparison, least privilege review, key/session revocation, privileged access monitoring.
Customer data confidentiality	Unauthorized access to customer information; contractual and regulatory exposure.	Data inventory, access log analysis, customer impact assessment, legal notification review.
Application configuration	Exposure of secrets, tenant settings, feature flags, or architecture details.	Secret rotation, configuration validation, environment hardening, follow-on compromise checks.
SaaS trust and customer operations	Customer concern, support volume, sales/reputation impact, audit requests.	Clear communications, customer FAQs, support scripts, executive sponsor outreach.

11. Observer Evaluation Prompts

For each statement, observers may rate confidence from 1 (not confident) to 5 (fully confident).

- We can quickly identify and validate anomalous privileged cloud activity.
- We can revoke sessions, rotate secrets, and disable access without losing critical evidence.
- We understand who owns containment decisions when business availability may be affected.
- We can determine which cloud storage objects and customers were affected.
- We can make timely, evidence-based customer and regulatory notification decisions.
- We can produce a defensible incident timeline and post-incident improvement plan.

12. Debrief and Lessons Learned

Debrief topic	Questions to capture
Detection and triage	What signal triggered action? Were alerts actionable? Were logs sufficient and retained long enough?
Containment	Were containment actions timely, reversible, approved, and evidence-aware?
IAM assurance	Could the team prove all unauthorized roles, keys, tokens, policies, and grants were removed?
Data exposure	Could the team determine affected customers, data elements, jurisdictions, and confidence level?
Governance and communications	Were escalation paths, decision rights, and communication approvals clear?
Remediation backlog	What owners, due dates, control improvements, and validation steps should be assigned?

13. Recommended Post-Exercise Improvements

- Maintain a cloud IAM break-glass and privileged access runbook that includes session revocation, key rotation, and emergency approval criteria.
- Implement continuous detection for unusual admin geography, impossible travel, high-risk API calls, new privileged roles, and storage access anomalies.
- Use infrastructure-as-code or policy-as-code baselines to detect and roll back unauthorized IAM drift.
- Ensure audit logs are immutable, centralized, retained, and queryable across identity provider, cloud control plane, storage, and SaaS application layers.
- Pre-stage legal/privacy decision trees for customer data exposure, including access-versus-exfiltration criteria and customer segmentation.
- Prepare customer support holding statements, executive briefing templates, and regulator notification templates for cloud data incidents.

14. MITRE ATT&CK Mapping

Technique	Relevant tactics	How reflected in scenario	Detection / response emphasis
T1078 - Valid Accounts	Initial Access; Persistence; Privilege Escalation; Defense Evasion	Attacker uses a legitimate cloud administrator account from an unusual region.	MFA and IdP review, anomalous location detection, session revocation, privileged account validation.
T1098 - Account Manipulation	Persistence; Privilege Escalation; Defense Evasion	Unauthorized privileged roles are created and administrator permissions are modified.	IAM drift detection, role/policy baseline comparison, key and service principal review.
T1530 - Data from Cloud Storage	Collection	Audit logs show unauthorized access to cloud storage containing customer information and application configuration data.	Storage access log review, object-level inventory, egress analysis, customer data exposure assessment.

ATT&CK references: MITRE ATT&CK Enterprise technique pages for T1078, T1098, and T1530 were used to validate current tactic and technique descriptions as of generation.

Appendix A - Source STIX Elements Used

STIX element	Value used in exercise
Identity	Nimbus SaaS Platform
Infrastructure	Cloud Management Environment

STIX element	Value used in exercise
Threat actor	Cloud Access Broker
Incident	Cloud Administrator Account Compromise: Compromised cloud administrator account results in unauthorized IAM modifications and access to customer data.
Courses of action	Revoke Compromised Credentials; Review Cloud IAM and Storage Access
Inject notes	Inject 1 - Suspicious Cloud Activity; Inject 2 - IAM Modification; Inject 3 - Customer Data Access; Inject 4 - Customer and Regulatory Notification